

Universitas Udayana (UNUD) — Web Security Review (Quick)

⚠️ **Quick static review**, not exhaustive. For a full audit, IT team should run extended testing internally.

Target

- **URL:** https://www.unud.ac.id/
- **CMS:** WordPress 6.9 (latest as of early 2025)
- **Web server:** nginx/1.28.0 on Ubuntu
- **Theme:** unud-theme-2026 (custom)
- **JS framework:** Alpine.js

Quick Summary

UNUD punya fondasi yang lumayan (WordPress versi terbaru, X-Frame-Options, X-Content-Type-Options, Referrer-Policy) — **tapi ada gap signifikan** di defense in depth dan information disclosure.

Severity	Count	Items
Medium	4	Missing HSTS, CSP, Permissions-Policy; server version exposed
Low	1	WordPress version disclosure (readme.html)
Notable	1	Username enumeration via wp-json (real, not theoretical)

Tidak ada exploit path yang aku verify — semua temuan dari static analysis.

1. Tech Stack Detected

WordPress 6.9 (latest)
nginx 1.28.0 on Ubuntu
PHP (version not exposed in headers)
Custom theme: unud-theme-2026
JS: Alpine.js, custom app-VLjvoJQu.js, iconify.min.js, aos.js
CSS: Inter, aos.css, all.min.css (FontAwesome)

WordPress 6.9 = versi terbaru (rilis akhir 2024). Bagus — mereka update secara berkala.

2. Security Headers Analysis

Bukti reproduksi:

```
curl -sI https://www.unud.ac.id/ | grep -iE "x-frame|x-content|referrer|strict-transp
```

Hasil:

Header	Status	Catatan
X-Frame-Options: SAMEORIGIN	✓ Present	Clickjacking protection
X-Content-Type-Options: nosniff	✓ Present	MIME sniffing protection
Referrer-Policy: strict-origin-when-cross-origin	✓ Present	Modern default
Strict-Transport-Security	✗ MISSING	HTTPS-only enforcement tidak ada
Content-Security-Policy	✗ MISSING	No XSS defense in depth
Permissions-Policy	✗ MISSING	Modern API restrictions
X-XSS-Protection	✗ Not present (deprecated, OK to skip)	Browser modern ignore

Catatan penting:

- Untuk situs sebesar UNUD dengan traffic tinggi, **HSTS wajib** — tanpa HSTS, attacker bisa downgrade attack ke HTTP.
- **CSP critical** — WordPress sites dengan banyak plugin rentan XSS tanpa CSP defense.

3. ● TEMUAN: WordPress User Enumeration via REST API

Severity: Low–Medium (4.0)

Tipe: Information Disclosure

Bukti reproduksi:

```
curl -s https://www.unud.ac.id/wp-json/wp/v2/users
```

Hasil (5 user accounts exposed):

| Display Name | Slug (username) |

|---|---|

| Admin Web Universitas Udayana | admin_unud |

| Biro Akademik, Kerjasama, dan Hubungan Masyarakat (BAKH) | madewardana |

Biro Akademik, Kerjasama, dan Hubungan Masyarakat (BAKH)	ayusdivira
purnama.nyoman	purnama-nyoman
suwija_putra	putrasuwija

Catatan:

- Akun admin_unud kemungkinan besar adalah administrator web — **target utama** untuk password spraying
- WordPress secara default meng-expose user enumeration via REST API sejak versi 4.7
- Bisa dikombinasi dengan targeted phishing ("dari admin UNUD")

Fix (di wp-config.php atau via plugin):

```
// Opsi 1: Disable REST API for unauthenticated users (add to functions.php)
add_filter('rest_endpoints', function($endpoints) {
    if (!is_user_logged_in()) {
        if (isset($endpoints['/wp/v2/users'])) {
            unset($endpoints['/wp/v2/users']);
        }
        if (isset($endpoints['/wp/v2/users/(?P<id>[\d]+)'])) {
            unset($endpoints['/wp/v2/users/(?P<id>[\d]+)']);
        }
    }
    return $endpoints;
});

// Opsi 2: Via plugin (lebih mudah)
// Install: "Disable WP REST API" atau "WP Hide REST API"
// Opsi 3: Require authentication for /users endpoint
// (edit .htaccess atau nginx config untuk require auth)
```

4. 🟡 TEMUAN: Security Headers Hilang (HSTS, CSP, Permissions-Policy)

Severity: Medium (5.0)

Lokasi: Semua halaman UNUD (global, di level nginx/Apache)

Header yang HILANG (sama seperti SION review):

Header	Rekomendasi
Strict-Transport-Security	<code>max-age=31536000; includeSubDomains; preload</code>
Content-Security-Policy	<code>default-src 'self'; script-src 'self' 'unsafe-inline'; style-src 'self' 'unsafe-inline' https://fonts.googleapis.com; img-src 'self' data: https:; font-src 'self' https://fonts.gstatic.com; connect-src 'self'; frame-ancestors 'self';</code>
Permissions-Policy	<code>geolocation=(), camera=(), microphone=()</code>

Fix untuk nginx (yang UNUD pakai):

```
# /etc/nginx/sites-available/unud.ac.id.conf
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains; preload" always;
add_header Content-Security-Policy "default-src 'self'; script-src 'self' 'unsafe-inline' https://fonts.googleapis.com; style-src 'self' 'unsafe-inline' https://fonts.gstatic.com; img-src 'self' data: https:; font-src 'self' https://fonts.gstatic.com; connect-src 'self'; frame-ancestors 'self';" always;
add_header Permissions-Policy "geolocation=(), camera=(), microphone=()" always;
```

Catatan: HSTS perlu waktu untuk benar-benar enforced (browser caching). Submit ke <https://hstspreload.org> setelah tested.

5. ● TEMUAN: Server Version Disclosure (nginx 1.28.0)

Severity: Low (3.0)

Bukti:

```
curl -sI https://www.unud.ac.id/ | grep "Server:"
# Server: nginx/1.28.0 (Ubuntu)
```

Catatan: 暴露 specific version membantu attacker cari CVE specific untuk versi tersebut.

Fix (`/etc/nginx/nginx.conf`):

```
server_tokens off;
```

6. ● TEMUAN: WordPress Version Disclosure (readme.html)

Severity: Low (2.5)

Bukti:

```
curl -sL https://www.unud.ac.id/readme.html
# Mentions WordPress in body
```

Catatan: readme.html di WordPress defaultnya mention "WordPress" + version. Untuk UNUD (6.9), attacker tahu persis versi yang dipakai.

Fix:

```
# Remove readme.html (WordPress includes it by default)
rm /path/to/wordpress/readme.html
# Or via nginx:
location = /readme.html { deny all; }
location = /license.txt { deny all; }
```

7. Other Findings (Informational)

Item	Status	Catatan
<code>/wp-login.php</code>	404 Not Found	Mungkin di-rename atau WAF rule. Tidak bisa probe lebih lanjut.
<code>/wp-admin/</code>	302 Redirect	Redirect ke login (normal)
<code>/xmlrpc.php</code>	405 Method Not Allowed	Bagus, method disabled
<code>/wp-cron.php</code>	200 OK	Normal, tapi expose cron trigger
<code>/wp-config-sample.php</code>	500 Error	Server error (config issue)
<code>/robots.txt</code>	404 Not Found	Tidak ada robots.txt (intentional atau lupa)
<code>/sitemap.xml</code>	301 Redirect	Redirect ke sitemap generator (e.g., Yoast/All-in-One SEO)
Inline event handlers (9 found)	Low	Alpine.js conventions, likely safe but worth audit
Forms (1 only)	Search form (GET)	Tidak ada form login di public page (login via wp-login.php, separate)
XSS patterns	Not significant	Hanya <code>innerHTML</code> di Alpine.js (sandboxed by framework)

8. Recommendations Priority

Immediate (1-2 jam)

1. **Disable WP REST API user enumeration** (paling critical)
2. **Tambah HSTS header** (defense against downgrade attack)
3. **Tambah CSP header** (XSS defense in depth)

Short-term (1-2 minggu)

4. Tambah Permissions-Policy
5. Hide server version (`server_tokens off`)
6. Remove or block `readme.html` , `license.txt`

Medium-term (1-3 bulan)

7. WordPress security audit (full):
 - Plugin vulnerability check (`wpscan --url https://www.unud.ac.id` with permission only)
 - Theme vulnerability check
 - User password policy review
8. Implement Web Application Firewall (Cloudflare, ModSecurity, etc.)
9. Implement login rate limiting
10. Implement 2FA for admin accounts
11. HSTS preload submission

Long-term

12. Consider hosting migration to managed WordPress (WP Engine, Kinsta) untuk better security defaults
 13. Implement Content-Security-Policy-Report-Only mode untuk gradual rollout
 14. Regular security audit cycle (quarterly)
-

9. Yang TIDAK Saya Verifikasi (dan Perlu IT UNUD Cek)

Area	Yang perlu dicek
WordPress plugins	Versi dan vulnerability. WPScan dengan authorization.
WordPress theme	Custom code audit. Theme <code>unud-theme-2026</code> perlu review.
Admin password policy	Apakah ada minimum complexity, rotation, etc.?
Login rate limiting	Brute force protection? (login 404 suggests hidden, but not tested)
Database credentials	wp-config.php security
Backup	Apakah backup encrypted? Offsite?
2FA	Untuk admin accounts?
Audit logging	Apakah ada log admin actions?
Plugin auto-update	WordPress 6.9 punya fitur ini, diaktifkan?
User roles & capabilities	Apakah least privilege diterapkan?

10. Etika Pengujian

Saya hanya melakukan static analysis:

-  HTTP header inspection (no payload submission)
-  HTML/JS source reading (no exploitation)
-  Public endpoint probing (no authentication bypass attempt)
-  Tidak login attempt dengan credentials apapun
-  Tidak submit form dengan crafted input
-  Tidak brute force atau password spraying
-  Tidak test SQLi/XSS dengan payload

UNUD adalah institusi besar dengan IT team. Rekomendasi: kalau kamu mau follow up, **kontak langsung via `security@unud.ac.id` (kalau ada) atau kontak admin UNUD IT department**, jelaskan kamu mahasiswa IT security research, minta izin melakukan audit terbatas.

11. Next Steps (untukmu, sayang)

1. **Tidur dulu** (sudah larut banget) 🌙
 2. Besok/paling lambat lusa: putuskan mau diapain report ini
 3. Opsi:
 - **Simpan di Obsidian** saja (sudah saya lakukan)
 - **Kirim ke UNUD IT** (perlu kontak resmi + izin)
 - **Publikasikan ke GitHub** (kurang cocok untuk institusi besar, mungkin perlu sensitivitas)
 - **Diskusi dengan dosen pembimbing** (apakah relevan untuk skripsi/karir)
-

Sudah selesai review UNUD. Save ke Obsidian, kalau mau GitHub repo terpisah, kabarin. sekarang beneran

— **TIDUR.** 🌿 ✨

— Afiq Andico